AGENERSA

Especificação do sistema Reajusta

15. Segurança

Capítulo do pacote de especificação

Minuta para avaliação: não é versão aprovada

Sistema	Reajusta: Sistema de reajuste tarifário anual das concessões de saneamento
Versão	1.0
Data	04/11/2026
Situação	Minuta para avaliação
Para quem	Tecnologia da informação e segurança
Leitura estimada	55 min

O que avaliar

1. Os itens deste capítulo estão corretos e completos?
2. Falta alguma regra, caso ou exceção que a sua área conhece?

Registre o parecer na planilha **05_Planilha_de_avaliacao.xlsx**, uma linha por item (filtre pela coluna “Quem avalia”). Ajuste pedido vai escrito, com o identificador do item.

Documento gerado a partir do pacote de especificação versão 1.0. Os números citados saem dos registros dos processos e são reproduzíveis. Horas e custos são hipótese até a calibração com os servidores.

Sumário

1. Alcance pelo ASVS 5.0
2. Autenticação
3. Sessão
4. Autorização
5. Validação de entrada e envio do pacote
6. Cabeçalhos HTTP e CSP
7. Limite de requisições
8. Segredos
9. Registro e auditoria
10. Proteção de dados
11. Infraestrutura de execução
12. Dependências e cadeia de suprimentos
13. Gestão de vulnerabilidades
14. Testes de segurança por etapa
15. Resposta a incidente: o mínimo
16. Exceções registradas
17. Itens propostos que tocam outros documentos
18. Matriz de verificações

15. Segurança

Requisitos de segurança do Reajusta, com a referência, o critério de aceite e a forma de verificar cada um. Este documento fecha a lacuna achada no início da aula 3: o pacote tinha o bloqueio de login e a varredura de segredos, mas não tinha referência de verificação, cabeçalhos e CSP, limite de requisições, SBOM, gestão de vulnerabilidades nem política de atualização de dependências.

- **Referência:** OWASP ASVS 5.0, nível 2. A coluna "Origem" cita o capítulo do ASVS (V1 a V16) e o requisito, a regra ou a seção do pacote que já pedia a mesma coisa.
- **Complementa, não repete:** a matriz de permissões, a autenticação, a trilha, a LGPD, os segredos e a implantação continuam em 14_OPERACAO.md (documento 14, Operação, acesso e LGPD). Aqui fica o que faltava e como cada item é verificado.
- **Decisões ligadas:** cadeia de suprimentos em adr/0012-cadeia-de-suprimentos.md; implantação no Railway em adr/0013-deploy-railway.md; modelo de linguagem pelo OpenRouter no adendo de adr/0006-modelo-de-linguagem-por-adaptador.md.
- **Valores "(proposto)"** são parâmetros de partida, confirmados com a TI na PARADA 14 (auditoria de segurança) e trocáveis sem mudar o requisito.
- **Quem verifica.** A auditoria de segurança (etapa D9, relatório `AUD-SEG-nn` em `docs/auditorias/` do repositório do sistema) usa as tabelas deste documento como lista de verificação. Quem audita não é quem construiu: um agente com contexto limpo, que recebe só esta lista, o código e a especificação.
- **Bloqueio é na CI.** Hooks do Claude Code e de git só avisam; nunca bloqueiam nem pedem entrada. O que bloqueia é o workflow do GitHub Actions (§18).

Colunas das tabelas de requisitos: **ID**, **Requisito**, **Origem**, **Critério de aceite**, **Release** (as de 01_VISAO_ESCOPO.md (documento 01, Visão, escopo e identificadores) §14; a etapa D0 a D11 da aula entre parênteses quando ajuda) e **Verificação** (ferramenta ou teste). Os caminhos de teste e de workflow são do repositório do sistema.

1. Alcance pelo ASVS 5.0

Capítulo do ASVS 5.0	Onde neste documento	Situação
V1 Codificação e sanitização	§5 (SEG-ENT-08)	aplica
V2 Validação e lógica de negócio	§5, §7	aplica
V3 Segurança do front-end web	§3, §6	aplica
V4 API e serviços web	§5, §6	aplica
V5 Tratamento de arquivos	§5	aplica
V6 Autenticação	§2	aplica; segundo fator em exceção (EXC-SEG-01)
V7 Gestão de sessão	§3	aplica
V8 Autorização	§4	aplica
V9 Tokens autocontidos	§3 (SEG-SES-04)	aplica: o JWT do NextAuth (ADR-0009)
V10 OAuth e OIDC	—	não aplica na R1: não há provedor OAuth (ADR-0009). Volta a aplicar se entrar login gov.br ou diretório da agência
V11 Criptografia	§2, §3, §10	aplica
V12 Comunicação segura	§6, §10	aplica
V13 Configuração	§8, §11	aplica

Capítulo do ASVS 5.0	Onde neste documento	Situação
V14 Proteção de dados	§10	aplica
V15 Codificação segura e arquitetura	§12, §13	aplica: dependências, SBOM, atualização
V16 Registro de segurança e tratamento de erro	§9	aplica
V17 WebRTC	—	não aplica: o sistema não usa WebRTC

2. Autenticação

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-AUT-01	Senha guardada só como hash argon2id, com parâmetros no mínimo de memória 19 MiB, 2 iterações e paralelismo 1. Senha com 12 caracteres no mínimo e 64 no máximo aceito, qualquer caractere (inclusive espaço e Unicode), sem regra de composição e sem expiração periódica. Senha da lista de senhas comuns é recusada	ASVS V6, V11; 14 §2; ADR-0009; RNF-10	Senha de 11 caracteres → recusada. Senha da lista → recusada. O valor gravado começa por `$argon2id$` e os parâmetros lidos dele são iguais ou maiores que os mínimos	R1	`tests/seguranca/senha.test.ts` (G-04); lista de senhas comuns versionada no repositório (o ASVS pede pelo menos as 3.000 mais comuns)
SEG-AUT-02	Falha de login responde a mesma mensagem e o mesmo código para usuário inexistente, senha errada e usuário bloqueado ou desativado. O caminho de usuário inexistente também calcula um hash argon2id, para não revelar a existência pelo tempo	ASVS V6; 07 §2.4	As três situações devolvem a mesma resposta. No usuário inexistente, a função de hash é chamada uma vez	R1	`tests/seguranca/login-sem-enumeracao.test.ts` (G-04)
SEG-AUT-03	Depois de 5 falhas seguidas, a conta fica bloqueada por 15 minutos (proposto). O desbloqueio antecipado é ação do PER-ADM. A falha e o bloqueio vão para a trilha sem a senha digitada	ASVS V6; 14 §2 e §3	A 6ª tentativa, mesmo com a senha certa, é recusada até o fim do bloqueio. A trilha tem um registro por falha e um de bloqueio, sem a senha	R1	`tests/seguranca/bloqueio-conta.test.ts` (G-07)
SEG-AUT-04	Primeiro acesso e recuperação de senha na R1 só pelo PER-ADM (TL-15). Ele gera uma senha provisória de uso único, válida por 24 horas (proposto). A troca é obrigatória no acesso seguinte. Não há recuperação por e-mail na R1. A troca de senha pede a senha atual e muda a versão da sessão (SEG-SES-03)	ASVS V6; 14 §2; ADR-0009	A senha provisória usada duas vezes ou depois de 24 h → recusada. Com a senha provisória, toda rota responde só o pedido de troca	R1	`tests/seguranca/senha-provisoria.test.ts` (G-07)
SEG-AUT-05	Segundo fator de autenticação para todos os perfis, começando por PER-ADM e PER-GCA	ASVS V6 (nível 2)	Ver EXC-SEG-01 (§16)	a decidir (TI)	AUD-SEG

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-AUT-06	Nenhuma senha de usuário de teste no repositório. O seed de homologação lê as senhas de segredos do ambiente. Com `APP_AMBIENTE=producao`, o seed não cria usuário de teste e para com erro se pedido. O primeiro PER-ADM de produção é criado por um comando de linha que a TI roda uma vez, com senha provisória (SEG-AUT-04)	P-12, P-17; 14 §5; ADR-0013	`gitleaks` sem achado no seed. Seed de usuários de teste com `APP_AMBIENTE=producao` → erro, nada criado	R1 (D10)	`tests/seguranca/seed.test.ts` (G-07); SEG-TST-03

3. Sessão

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-SES-01	Cookie de sessão `httpOnly`, `Secure`, `SameSite=Lax`, com prefixo `__Secure-` ou `__Host-`. Nenhum token em `localStorage` ou `sessionStorage`	ASVS V3, V7; 14 §2	O cookie lido no teste de ponta a ponta tem os quatro atributos. Nenhuma chamada a `localStorage` ou `sessionStorage` grava token	R1	`tests/e2e/seguranca/cookie.spec.ts` (G-09); regra Semgrep `token-em-storage` (SEG-TST-01)
SEG-SES-02	Expiração de 30 minutos sem uso e de 8 horas no total (14 §2; `SESSAO_MAX_MINUTOS`), conferidas no servidor a cada requisição pelos instantes gravados no token, com aviso antes de expirar (RNF-10)	ASVS V7; 14 §2	Token com mais de 8 h desde a emissão ou mais de 30 min sem uso → 401 e volta à TL-16	R1	`tests/seguranca/expiracao-sessao.test.ts` (G-04), com relógio falso (porta `Relogio`)
SEG-SES-03	Revogação pela versão da sessão do usuário. Desativar o usuário, trocar a senha, trocar os perfis ou desbloquear muda a versão e derruba as sessões abertas na requisição seguinte. Sair apaga o cookie e grava a trilha	ASVS V7; 14 §2; ADR-0009	Depois da troca de senha, a requisição com o token antigo → 401	R1	`tests/seguranca/revogacao-sessao.test.ts` (G-07)
SEG-SES-04	O token leva só o identificador do usuário, os perfis, o perfil ativo, a unidade, a concessionária, a versão da sessão e os instantes de emissão e de último uso. Nunca nome, e-mail ou CPF. `NEXTAUTH_SECRET` com pelo menos 32 bytes aleatórios; a configuração recusa valor menor	ASVS V9, V11; P-05; 14 §2 e §5	O token decodificado no teste não tem outra chave. Partida com segredo curto → o processo para com erro de configuração	R1	`tests/seguranca/conteudo-token.test.ts` (G-04); `composicao/config.ts` validado com Zod (05 §15)
SEG-SES-05	Proteção contra CSRF: o NextAuth protege as rotas de autenticação. Toda mutação (`POST`, `PUT`, `PATCH`, `DELETE`) autenticada por cookie confere o cabeçalho `Origin`; ausente ou diferente da origem de `NEXTAUTH_URL` → 403 `sem-permissao`. Chamada de sistema com `Bearer` (07 §2.8) não usa cookie e não passa por essa conferência	ASVS V3; 14 §2	Mutação com cookie válido e `Origin` de outro domínio → 403; sem `Origin` → 403	R1	`tests/seguranca/csrf.test.ts` (G-07)

4. Autorização

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-AUZ-01	Negar por padrão. Toda rota exige sessão, menos a entrada (TL-16), a rota de saúde (14 §6) e os arquivos estáticos do build. A lista de rotas públicas é fechada, num arquivo só da interface	ASVS V8; AGENTS_DESENVOLVIMENTO §11	Para cada operação do `contratos/openapi.yaml`, a chamada sem sessão → 401	R1	`tests/seguranca/rotas-sem-sessao.test.ts` (G-07), que percorre o OpenAPI
SEG-AUZ-02	Autorização por perfil. Todo caso de uso chama `permite(perfis, acao, recurso)` antes de agir. A matriz de 14_OPERACAO.md (documento 14, Operação, acesso e LGPD) §1 é a fonte única: o teste lê a tabela da §1 e a compara, célula por célula, com `permite`. O `x-perfis` de cada operação do OpenAPI bate com a matriz	ASVS V8; 14 §1; ADR-0009; RF-ADM-01; RNF-10	Nenhuma diferença entre a tabela da §1, `permite` e `x-perfis`. Para cada operação, um perfil fora de `x-perfis` → 403 `sem-permissao`	R1	`tests/seguranca/matriz-permissoes.test.ts` (G-04); `tests/seguranca/rotas-perfis.test.ts` (G-07)
SEG-AUZ-03	Autorização por concessionária. O PER-CON só alcança ciclo, pleito, evidência, contrato e remessa da concessionária do seu vínculo. O filtro fica na aplicação e no repositório, nunca na tela. Recurso de outra concessionária → 404 `nao-encontrado`, sem revelar que existe; a tentativa vai para a trilha	ASVS V8; 14 §1 nota 1; AT-25; RF-ADM-01	AT-25 verde pela tela e pela API. Teste de acesso cruzado em toda operação que recebe identificador de recurso de concessionária, inclusive o download de arquivo	R1	`tests/seguranca/acesso-cruzado.test.ts` (G-07); AT-25 no e2e (G-09)
SEG-AUZ-04	Arquivo só sai pela rota que confere a permissão do recurso dono (pleito, peça, remessa). Nada é servido direto do volume. Identificadores externos são UUID, mas a proteção não depende de serem difíceis de adivinhar	ASVS V5, V8; 14 §6	Pedir o arquivo de uma evidência de outra concessionária pelo identificador correto → 404	R1	`tests/seguranca/acesso-cruzado.test.ts` (G-07)
SEG-AUZ-05	A autorização não depende do middleware do Next.js. O middleware, se existir, só põe cabeçalhos e o nonce da CSP. A versão do Next.js no lockfile é 15.2.3 ou posterior, a correção do CVE-2025-29927 (desvio de autorização no middleware)	ASVS V8, V15	Requisição a rota protegida com o cabeçalho `x-middleware-subrequest` forjado → 401. Lockfile com Next.js anterior a 15.2.3 → falha	R1	`tests/seguranca/middleware.test.ts` (G-07); OSV-Scanner (SEG-TST-02)
SEG-AUZ-06	Segregação: o usuário que publicou a versão do cadastro (PER-GCA) não confirma a validação do pleito que a usa no mesmo ciclo (PER-ANA)	ASVS V2, V8; 14 §1 (segregação, proposto)	O mesmo usuário nas duas ações → 422 `regra-negocio` e registro na trilha	R1	`tests/seguranca/segregacao.test.ts` (G-04)

5. Validação de entrada e envio do pacote

O envio do pleito é a maior superfície de entrada (RF-PLE-01, UC-01, TL-03). As regras valem também para a validação prévia (RF-PLE-05) e, na R4, para a remessa (RF-FAT-01).

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-ENT-01	Toda entrada é validada na borda: Zod no corpo, na consulta, no caminho e nos cabeçalhos usados; Ajv com o layout (V01). Propriedade fora do layout → 422 `campo-fora-do-layout`, nada guardado. `Content-Type` diferente do previsto → 415 `tipo-nao-suportado`	ASVS V2, V4; RF-PLE-01; RF-PLE-02; RNF-05; 07 §2.4	Pacote de Paraty 2026 com uma propriedade a mais → 422 e nenhuma linha nova no banco nem arquivo no volume	R1	`tests/seguranca/entrada.test.ts` (G-07)
SEG-ENT-02	Tamanho máximo: pacote inteiro `PACOTE_MAX_BYTES` (proposto: 25 MiB), cada arquivo `ARQUIVO_MAX_BYTES` (proposto: 10 MiB), no máximo 20 anexos (proposto). `Content-Length` acima do limite → 413 `pacote-grande-demais` antes de ler o corpo. Sem `Content-Length`, ou com valor falso, a leitura conta os bytes e para no limite. Calibrar os limites com os pacotes reais	ASVS V4, V5; 07 §2.4 (413)	Pacote de 26 MiB → 413 sem ler o corpo inteiro. Corpo de 26 MiB com `Content-Length` falso → 413 e memória do processo sem pico do tamanho do corpo	R1	`tests/seguranca/tamanho-pacote.test.ts` (G-07)
SEG-ENT-03	O tipo é conferido pelo conteúdo, não pela extensão nem pelo `Content-Type` declarado. Aceitos na R1: `pleito.json` (JSON em UTF-8), CSV (texto UTF-8 sem byte nulo) e PDF (começa por `%PDF-`). Qualquer outro, inclusive ZIP, planilha, HTML, SVG e executável → 415 `tipo-nao-suportado`	ASVS V5; RF-PLE-01; UC-01	Um HTML renomeado para `.csv` → 415. Um PDF renomeado para `.csv` → 415	R1	`tests/seguranca/tipo-arquivo.test.ts` (G-07)
SEG-ENT-04	O SHA-256 de cada arquivo é recalculado do conteúdo recebido e comparado com `anexos[].sha256`, como manda o RF-PLE-01. O hash do pacote identifica o reenvio (409 `pacote-duplicado`) e a `Idempotency-Key` evita a duplicação (07 §2.6)	ASVS V5; RF-PLE-01; 07 §2.6	Os critérios 1 a 3 do RF-PLE-01 verdes	R1	testes do RF-PLE-01 (G-07)

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-ENT-05	O nome do arquivo nunca vira caminho. A chave de armazenamento é um UUID gerado pelo sistema. O nome original fica só como texto (até 255 caracteres, sem `/`, `\`, `..` nem caractere de controle) e é exibido escapado. O download responde com `Content-Disposition: attachment` e nome codificado (`filename*=UTF-8''…`), `X-Content-Type-Options: nosniff` e `Content-Security-Policy: sandbox`	ASVS V5; AGENTS_DESENVOLVIMENTO §11; 06 (`caminhoArmazenamento`)	Anexo chamado `../../x.csv` é guardado sob UUID, sem arquivo fora da raiz de `ARQUIVOS_DIR`. A resposta de download tem os três cabeçalhos	R1	`tests/seguranca/nome-arquivo.test.ts` (G-07)
SEG-ENT-06	Dado pessoal é recusado antes de gravar, por `contemDadoPessoal` (CPF com dígito verificador, coluna ou campo de nome de pessoa, e-mail pessoal) nos campos de texto livre do JSON e nos cabeçalhos e colunas dos CSV. Nada é gravado. A mensagem diz o campo ou a coluna a retirar e não repete o valor. O log e a trilha registram a recusa sem o conteúdo. O PDF não é inspecionado na R1: a publicação e a memória assinada trazem nomes de signatários, que o 14 §4 admite	ASVS V14; RNF-05; 14 §4; AT-22; P-05	AT-22 verde. O valor recusado não aparece na resposta, no log nem na trilha	R1	AT-22 (G-07); teste de redação de log (SEG-LOG-02)
SEG-ENT-07	Arquivo recebido não é executado nem interpretado além do necessário. Na R1, o PDF só é guardado e devolvido; não é aberto, convertido nem renderizado no servidor. O CSV é lido por analisador com limites de 50.000 linhas, 200 colunas e 10.000 caracteres por célula (proposto)	ASVS V5	CSV com 50.001 linhas → recusado com mensagem do guia, sem queda do processo	R1	`tests/seguranca/csv-limites.test.ts` (G-04)
SEG-ENT-08	Saída codificada. React escapa o texto; `dangerouslySetInnerHTML` é proibido. Prisma só com consultas parametrizadas; `$queryRawUnsafe` e `$executeRawUnsafe` são proibidos. CSV exportado (memória de cálculo, trilha) prefixa com apóstrofo a célula de texto que começa com `=`, `+`, `-`, `@`, tabulação ou retorno de carro; célula numérica continua número	ASVS V1; 14 §3 (exportação da trilha); RF-CAL-03	Regras Semgrep sem achado. Célula de texto `=HYPERLINK(...)` sai como `'=HYPERLINK(...)`	R1	regras Semgrep `html-perigoso`, `sql-inseguro` (SEG-TST-01); `tests/seguranca/csv-formula.test.ts` (G-04)

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-ENT-09	Nenhuma URL de saída vem do usuário. Os endereços das fontes vêm da configuração (05 §15). Endereço alterado pelo PER-ADM na TL-15 (HIS-ADM-06) tem de usar HTTPS e estar na lista de hosts permitidos `INTEGRACOES_HOSTS_PERMITIDOS` (proposto); fora dela → recusado	ASVS V12, V13; HIS-ADM-06; P-03	Endereço `http://169.254.169.254/` ou de host fora da lista → recusado e registrado na trilha	R1	`tests/seguranca/hosts-permitidos.test.ts` (G-04)

6. Cabeçalhos HTTP e CSP

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-CAB-01	CSP estrita com nonce novo a cada requisição: `default-src 'self'; script-src 'self' 'nonce-<n>' 'strict-dynamic'; style-src 'self' 'nonce-<n>'; img-src 'self' data: blob:; font-src 'self'; connect-src 'self'; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'; upgrade-insecure-requests`. Proibidos `'unsafe-inline'` e `'unsafe-eval'` em `script-src` fora do ambiente de desenvolvimento. A única concessão permitida é `style-src-attr 'unsafe-inline'`, e só se um componente do inventário (10_UX_UI §5) precisar, registrada no AUD-SEG. O nonce chega aos scripts do Next.js e ao `next-themes`	ASVS V3; RNF-10	Toda página tem o cabeçalho com nonce diferente entre duas requisições. Nenhuma violação de CSP no console durante o e2e	R1	`tests/seguranca/cabecalhos.test.ts` (G-07); e2e falha em violação de CSP (G-09); ZAP baseline (SEG-TST-04)
SEG-CAB-02	Só HTTPS: `Strict-Transport-Security: max-age=31536000; includeSubDomains`. Pedido em HTTP é redirecionado para HTTPS pela borda (ADR-0013)	ASVS V12	Resposta de homologação com o cabeçalho; `http://` → redirecionado	R1 (D10)	verificação de cabeçalhos no `deploy.yml` (SEG-TST-06)
SEG-CAB-03	Demais cabeçalhos em toda resposta: `X-Content-Type-Options: nosniff`; `Referrer-Policy: no-referrer`; `Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=(), usb=()`; `X-Frame-Options: DENY`; `Cross-Origin-Opener-Policy: same-origin`; `Cross-Origin-Resource-Policy: same-origin`. Sem `X-Powered-By` e sem versão de servidor	ASVS V3, V13	Os seis cabeçalhos presentes em página, API, download, 404 e 500; `X-Powered-By` ausente	R1	`tests/seguranca/cabecalhos.test.ts` (G-07); `deploy.yml`
SEG-CAB-04	`Cache-Control: no-store` em toda resposta autenticada e em toda resposta da API. Só os arquivos estáticos do build têm cache longo	ASVS V14	Resposta de `GET /api/v1/ciclos` com `no-store`	R1	`tests/seguranca/cabecalhos.test.ts` (G-07)
SEG-CAB-05	Sem CORS: a API não envia `Access-Control-Allow-Origin` e não responde pré-verificação de outra origem com permissão	ASVS V3, V4	Pré-verificação com `Origin` de outro domínio → sem cabeçalho `Access-Control-Allow-*`	R1	`tests/seguranca/cabecalhos.test.ts` (G-07)

7. Limite de requisições

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-LIM-01	Login: no máximo 20 tentativas a cada 5 minutos por endereço IP (proposto), além do bloqueio por conta (SEG-AUT-03). Acima → 429 `muitas-requisicoes` com `Retry-After`	ASVS V2, V6; 07 §2.4 (429)	A 21ª tentativa do mesmo IP em 5 min → 429 com `Retry-After`	R1	`tests/seguranca/limite-login.test.ts` (G-07)
SEG-LIM-02	Envio do pleito (`POST /ciclos/{ciclo_id}/pleitos`): no máximo 10 por hora por usuário (proposto). Validação prévia (`POST /pleitos/validacao-previa`): no máximo 30 por hora por usuário (proposto). Acima → 429 com `Retry-After`	ASVS V2; RNF-13; 07 §2.4	O 11º envio na hora → 429. O reenvio com a mesma `Idempotency-Key` não conta como envio novo	R1	`tests/seguranca/limite-pleito.test.ts` (G-07)
SEG-LIM-03	O limite é aplicado na interface, antes do caso de uso, e não no middleware (SEG-AUZ-05). Contador na memória do processo `web` , que tem uma instância só (ADR-0013). O IP é o que a borda do Railway informa; o valor enviado pelo cliente é ignorado. Com mais de uma instância, o contador passa para o PostgreSQL, o que muda o modelo de dados e exige pedido (AGENTS_DESENVOLVIMENTO §10)	ASVS V2; ADR-0013; P-13	Cabeçalho `X-Forwarded-For` forjado pelo cliente não muda o IP contado	R1	`tests/seguranca/limite-login.test.ts` (G-07)

8. Segredos

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-SEC-01	Nenhum segredo no repositório, na imagem, no log ou na saída de workflow. O repositório tem só `.env.example` com os nomes. Só `composicao/config.ts` lê `process.env`	ASVS V13; P-12; RNF-10; 14 §5	`gitleaks` sem achado no PR, no histórico inteiro e no sistema de arquivos da imagem. Regra Semgrep `process-env-fora-config` sem achado	R1	SEG-TST-03; regra Semgrep (SEG-TST-01)
SEG-SEC-02	Onde os segredos ficam: no Railway, variáveis seladas por ambiente; no GitHub, segredos de ambiente (`RAILWAY_TOKEN` em `homologacao` e em `producao`) e de repositório (`OPENROUTER_API_KEY` , só no workflow de triagem). Nenhum workflow imprime segredo: sem `set -x` em passo com segredo, valor derivado mascarado. A chave do OpenRouter é testada por `GET /api/v1/key` antes de virar segredo, sem exibir o valor	ASVS V13; 14 §5; ADR-0013	Nenhum valor de segredo nos logs do Actions nem no painel do Railway depois de selado	R1 (D10, D11)	revisão do workflow na AUD-SEG; `gitleaks` nos logs baixados do Actions
SEG-SEC-03	Inventário e rotação. Somam-se aos de 14 §5: `OPENROUTER_API_KEY` (triagem; a cada 90 dias (proposto) e em incidente), `RAILWAY_TOKEN` por ambiente (em troca de equipe e em incidente), senhas dos papéis `reajusta_app` e `reajusta_dono` (idem) e senhas dos usuários de teste de homologação (a cada release). A troca de `NEXTAUTH_SECRET` derruba todas as sessões	ASVS V13; 14 §5	Inventário no `docs/seguranca/SEGREDOS.md` do repositório do sistema, com dono, data da última troca e próxima troca; nenhum vencido	R1 (D10)	relatório semanal (SEG-VUL-07) aponta rotação vencida

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-SEC-04	Menor alcance: token de projeto do Railway restrito a um ambiente; `permissions` mínimos em cada workflow (`contents: read` por padrão); chave do OpenRouter com limite de crédito; a chave do OpenRouter não é variável do Railway enquanto o sistema não chama modelo de linguagem (R1)	ASVS V13; ADR-0013; adendo do ADR-0006	Nenhum workflow com `permissions: write-all`. O serviço `web` da R1 sem `OPENROUTER_API_KEY`	R1 (D10, D11)	regra de lint de workflow na AUD-SEG; inventário de variáveis no `AMBIENTES.md`
SEG-SEC-05	Configuração falha fechada: a partida valida tudo com Zod e para se faltar valor ou se o valor for o de exemplo (`.env.example`) em `homologacao` ou `producao`	ASVS V13; 05 §15	Partida com `NEXTAUTH_SECRET` igual ao do exemplo e `APP_AMBIENTE=producao` → erro e processo encerrado	R1	`tests/seguranca/config.test.ts` (G-04)

9. Registro e auditoria

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-LOG-01	Eventos de segurança na trilha (14 §3): entrada, saída, falha de autenticação, bloqueio e desbloqueio, negação de permissão (403) e tentativa de acesso cruzado (404 de outra concessionária), recusa de envio com o motivo e sem o conteúdo, troca de senha, mudança de perfil, exportação. Cada registro com `correlacaoId`, perfil ativo e IP (só na trilha)	ASVS V16; 14 §3; RF-ADM-02; RNF-11; AT-25	Cada evento da lista gera um registro no teste; nenhum tem senha, token ou conteúdo recusado	R1	`tests/seguranca/eventos-trilha.test.ts` (G-07); AT-26
SEG-LOG-02	Log técnico sem dado pessoal, segredo, conteúdo de peça ou série paga (ARQ-33; 14 §7.2). Um teste percorre as rotas com dados que contêm esses campos e falha se algum aparecer no log	ASVS V16; P-05; P-11; 14 §7.2	Teste verde; log de exemplo com os campos sai redigido	R1	`tests/seguranca/redacao-log.test.ts` (G-07)
SEG-LOG-03	Erro sem detalhe técnico: `application/problem+json` sem pilha, SQL, caminho ou versão de componente; `erro-interno` leva só o `correlacao_id` (ARQ-26 a ARQ-28)	ASVS V16, V13	Falha forçada no adaptador responde 500 só com `codigo` e `correlacao_id`	R1	`tests/seguranca/erro-sem-detalhe.test.ts` (G-07); ZAP baseline
SEG-LOG-04	Alertas de segurança, somados aos de 14 §7.4: mais de 50 falhas de login em 10 minutos (proposto); qualquer tentativa de acesso cruzado entre concessionárias; falha das verificações noturnas (§18). O JOB-03, que já confere a cadeia de hash da trilha, conta os eventos do dia e cria `Alerta` para o PER-ADM acima do limiar (proposto)	ASVS V16; 14 §7.4; JOB-03	Simulação de 51 falhas em 10 min → um `Alerta` para o PER-ADM	R1	`tests/seguranca/alerta-seguranca.test.ts` (G-07)
SEG-LOG-05	Hora em UTC na trilha e no log. A retenção da trilha é a de 14 §4 (proposto: 5 anos). A retenção dos logs no Railway depende do plano e é registrada no `AMBIENTES.md`	ASVS V16; 14 §3 e §4	Registro com instante em UTC	R1 (D10)	AUD-SEG

10. Proteção de dados

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-DAD-01	Minimização da LGPD conforme 14 §4. Homologação e testes só com fixtures e dados sintéticos; nenhum usuário real de concessionária em homologação; nenhum dado real de pessoa em teste, fixture, seed ou exemplo	ASVS V14; RNF-05; 14 §4 e §5; P-17	`gitleaks` e a regra Semgrep `cpf-literal` sem achado em `tests/`, `prisma/seed/` e fixtures	R1	SEG-TST-01, SEG-TST-03
SEG-DAD-02	Em trânsito: só HTTPS entre navegador e borda (SEG-CAB-02); banco, Gotenberg e worker só na rede privada do Railway (ADR-0013); fontes externas por HTTPS sempre que a fonte aceitar (exceção do IPEADATA em EXC-SEG-03)	ASVS V12	Nenhuma porta pública além da do `web`; `IPEADATA_URL_BASE` em HTTPS ou exceção registrada	R1 (D10)	verificação de superfície no `deploy.yml` (SEG-INF-01)
SEG-DAD-03	Série paga não sai do processo: nada de painel público, exportação, API pública ou envio ao modelo de linguagem (P-11, ADR-0008)	ASVS V14; RNF-04; AT-24	AT-24 verde	R4 (AT-24); filtro desde R1	AT-24
SEG-DAD-04	Envio ao modelo de linguagem (a partir da R3) só depois da política de dados decidida na PARADA 11, sem dado pessoal e sem série paga. Pelo OpenRouter, o adaptador pede provedores que não retêm dados para treino (adendo do ADR-0006)	ASVS V14; INT-06; ADR-0006; RNF-05	Pedido montado no teste sem campo pessoal nem valor de série paga; preferência de não retenção presente no corpo	R3	testes do adaptador `openrouter` (G-07)
SEG-DAD-05	Localização. A região do Railway é registrada no `AMBIENTES.md`. Se ficar fora do Brasil, guardar dado real é transferência internacional (Lei 13.709/2018, art. 33). O sistema da aula é de demonstração: dado real de produção da agência só entra depois da PARADA 15, com a decisão da TI e da Procuradoria sobre a hospedagem e o relatório de impacto (14 §4)	ASVS V14; 14 §4; README PARADA 11	Registro da região e da decisão antes da carga de dado real	R1 (D10)	PARADA 15
SEG-DAD-06	Cópias de segurança conforme 14 §7.1. No Railway, apagar o volume apaga as cópias dele; por isso, antes de dado real, há uma cópia independente, cifrada e fora do projeto do Railway (ADR-0013)	ASVS V14; 14 §7.1	Restauração mensal registrada; cópia independente existe antes da carga de dado real	R1 (D10)	runbook de restauração; PARADA 15
SEG-DAD-07	No navegador: nada sensível em armazenamento local; nenhum dado pessoal em URL ou parâmetro de consulta (P-05); `Cache-Control: no-store` (SEG-CAB-04)	ASVS V14, V3	Regras Semgrep `token-em-storage` e `dado-pessoal-em-url` sem achado	R1	SEG-TST-01

11. Infraestrutura de execução

Detalhe da implantação em adr/0013-deploy-railway.md. 14_OPERACAO.md (documento 14, Operação, acesso e LGPD) §6 continua valendo.

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-INF-01	Superfície pública mínima: só o serviço `web` tem domínio público. PostgreSQL sem proxy TCP público. `worker`, `gotenberg` e `migracao` sem domínio	ASVS V13; ADR-0013; 14 §6	A listagem de domínios e de proxies TCP do ambiente mostra só o domínio do `web`	R1 (D10)	passo de superfície no `deploy.yml`, pela API do Railway

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-INF-02	O processo da aplicação não roda como root e não grava fora de `/tmp` e de `ARQUIVOS_DIR`. Onde o volume exige partida como root (ADR-0013), a entrada só ajusta o dono de `ARQUIVOS_DIR` e passa a execução ao usuário sem privilégio	ASVS V13; 14 §6	Na imagem, `id -u` diferente de 0 e escrita em `/app` negada. No `web` do Railway, o processo da aplicação com usuário diferente de 0	R1 (D1, D10)	teste da imagem no `verificar.yml`; conferência por `railway ssh` no runbook
SEG-INF-03	Papéis do banco separados: `reajusta_app` (aplicação; sem `UPDATE` nem `DELETE` na trilha; sem DDL), `reajusta_dono` (dono do esquema; só no serviço `migracao`) e o superusuário (só a TI, em nenhum serviço da aplicação)	ASVS V13, V8; 05 §3; 14 §3 e §5; RNF-11	AT-26 verde também em homologação, com o usuário `reajusta_app`	R1 (D10)	AT-26 no smoke de homologação
SEG-INF-04	Imagens fixadas por digest; implantação por digest; produção recebe o mesmo digest que passou em homologação (ADR-0012, ADR-0013)	ASVS V15; 14 §6	O digest implantado em produção é igual ao registrado no deploy de homologação aprovado	R1 (D10)	`deploy.yml` compara os digests
SEG-INF-05	Gotenberg só na rede privada; a busca de URL remota e os webhooks do Gotenberg desligados pela configuração; o sistema só usa a rota de conversão do LibreOffice	ASVS V12, V13; 05 §3	Pedido ao Gotenberg com URL remota → recusado. Saída para a internet não bloqueável: EXC-SEG-05	R1 (D10)	`tests/integracao/gotenberg.test.ts` (G-07)

12. Dependências e cadeia de suprimentos

Política completa em adr/0012-cadeia-de-suprimentos.md.

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-SUP-01	`package-lock.json` versionado; `npm ci` na CI e no Dockerfile; versões exatas no `package.json` (`save-exact`); um só registro (`registry.npmjs.org`) em todo `resolved` do lockfile	ASVS V15; ADR-0001; ADR-0012	`npm ci` falha com lockfile fora de sincronia. Um `resolved` de outro host → falha	R1	job `lockfile` do `seguranca-ci.yml`
SEG-SUP-02	Quarentena de 3 dias para versão nova de dependência, imagem base e action (`minimumReleaseAge` de 3 dias no Renovate). Motivo: ataques de cadeia de suprimentos publicam versões maliciosas que costumam ser retiradas em horas ou poucos dias. Exceção: atualização que corrige vulnerabilidade conhecida (`vulnerabilityAlerts` do Renovate, com os dados do OSV) entra sem quarentena, de qualquer severidade, sempre com revisão humana	ADR-0012 (revisão de 01/11/2026, R4)	Nenhum PR do Renovate com versão publicada há menos de 3 dias, salvo os marcados `seguranca`; `renovate.json` com `minimumReleaseAge` de 3 dias e `vulnerabilityAlerts.minimumReleaseAge` nulo	R1 (D11)	`renovate.json` revisado na AUD-SEG

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-SUP-03	Atualização de componente existente (patch, minor ou major): PR aberto automaticamente pelo Renovate, com a CI completa e merge humano. O PR de major leva o rótulo `major`, não exige ADR novo e atualiza o registro de versões (`docs/especificacao/adr/registro-versoes.md`) com versão, data e notas de migração. Dependência nova (nome novo no `package.json`), troca de biblioteca, imagem nova (nome de imagem novo no Dockerfile ou no `docker-compose.yml`) ou serviço novo: ADR novo e decisão humana (P-13). Etiqueta nova de imagem já usada é atualização, não imagem nova. A CI falha o PR que acrescenta nome ao `package.json`, imagem ao Dockerfile ou serviço ao `docker-compose.yml` sem arquivo novo em `docs/especificacao/adr/` no mesmo PR	P-13; ADR-0012 (revisão de 01/11/2026, R3, R5 e R6)	PR que acrescenta um pacote sem ADR → vermelho. PR que só muda a versão de um pacote existente, inclusive major, passa sem ADR. PR de major sem a linha nova no registro de versões → não recebe merge	R1	job `dependencias-novas` do `seguranca-ci.yml`; lista do PR (`.github/pull_request_template.md`)
SEG-SUP-04	Nenhum merge automático. O Renovate não faz merge; o token do GitHub Actions não aprova PR; o agente de segurança abre issue e PR, nunca faz merge	ADR-0012; plano da aula 3	`automerge` falso no `renovate.json`; configuração do repositório sem permissão de aprovação pelo Actions	R1 (D11)	AUD-SEG
SEG-SUP-05	SBOM CycloneDX a cada build: um do lockfile e um da imagem, guardados com a versão e comparados com o anterior	ASVS V15; ADR-0012	Cada execução do `deploy.yml` e do `seguranca-diaria.yml` publica os dois SBOM como artefato	R1 (D9, D11)	`npm sbom --sbom-format cyclonedx`; Syft na imagem
SEG-SUP-06	Proveniência: `npm audit signatures` sem assinatura inválida; GitHub Actions fixadas por SHA de commit; imagens base por digest; imagem do sistema implantada por digest e, se o plano do GitHub permitir, com atestado de proveniência conferido no deploy	ASVS V15; ADR-0012	`npm audit signatures` verde; nenhuma action referida por etiqueta móvel	R1	job `proveniencia` do `seguranca-ci.yml`
SEG-SUP-07	Alerta, sem bloqueio, de pacote novo na árvore (inclusive transitivo), mantenedor trocado em dependência direta e pacote novo com script de instalação. O alerta vira issue para triagem	ADR-0012	No exercício do D11, um pacote novo na árvore gera a issue	R1 (D11)	`seguranca-diaria.yml` (diferença entre SBOM; `npm view <pacote> maintainers`)
SEG-SUP-08	Python do oráculo no job de paridade com versões fixas e hashes (`pip install --require-hashes`)	ASVS V15; 05 §16	Job `paridade` falha com pacote sem hash	R1	job `paridade` do `verificar.yml`

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-SUP-09	Todo componente fica na última versão estável publicada: pacotes npm, Python do oráculo, imagens (`node`, `postgres`, `gotenberg`), GitHub Actions, runtime Node.js (última LTS) e PostgreSQL (última major estável). Versão beta, rc, canary ou nightly nunca entra. Prazo para alcançar a última estável, contado da publicação da primeira versão estável mais nova que a em uso: patch e minor em até 7 dias; major em até 30 dias (Node.js: da entrada da linha em LTS). Correção de segurança segue SEG-VUL-03, o que for menor. Componente atrás da última estável depois do prazo é exceção: entrada no registro de versões com motivo verificável (link do issue que bloqueia) e condição de saída, revisada no relatório semanal (SEG-VUL-07). O `seguranca-diaria.yml` lista todo dia os componentes atrasados (`npm outdated`, etiquetas das imagens, versões das actions, pacotes do Python do oráculo, Node.js, PostgreSQL), com os dias de atraso, e abre issue `versao-atrasada` quando um prazo vence. O branch de exercício do D11 fica fora	ADR-0012 (revisão de 01/11/2026, R1, R2, R5 e R7)	No `main`, componente com prazo vencido → issue `versao-atrasada` na execução seguinte, uma por componente e versão-alvo; versão de pré-lançamento (`-beta`, `-rc`, `-canary`, `-nightly`) no lockfile, no Dockerfile ou nas actions aparece no relatório como violação	R1 (D11)	relatório de atraso do `seguranca-diaria.yml`; AUD-SEG

13. Gestão de vulnerabilidades

13.1 Fontes e triagem

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-VUL-01	O `seguranca-diaria.yml` cruza os SBOM com: OSV (OSV-Scanner); GitHub Advisory Database, ecossistema npm (`gh api /advisories`); catálogo CISA KEV (JSON público, exploração ativa); avisos de segurança publicados nos repositórios do Next.js, do React e do Prisma; imagens base (`node`, `postgres`, `gotenberg`), pela varredura da imagem	ASVS V15; plano da aula 3	Cada fonte consultada aparece no resumo da execução com data e número de achados; fonte fora do ar aparece como falha, não como zero	R1 (D11)	`seguranca-diaria.yml`
SEG-VUL-02	Triagem por modelo de linguagem pelo OpenRouter (`ferramentas/triagem_vulnerabilidades.ts`, skill `triagem-vulnerabilidade`; modelo por `LLM_MODELO`). Para cada achado responde: a versão afetada está em uso? O código chama a parte vulnerável (busca de importações e rotas)? Há exploração ativa (KEV)? Qual a severidade e o prazo pela política? A resposta é validada por esquema. O pedido leva o aviso, a versão e os trechos de importação encontrados, nunca segredo, dado ou o código inteiro. **A triagem propõe; não baixa severidade nem fecha registro sozinha**: baixar exige decisão humana registrada	plano da aula 3; adendo do ADR-0006	No exercício do D11 (Next.js anterior a 15.2.3, CVE-2025-29927), a triagem marca "em uso", "alcançável" (o sistema tem middleware ou rotas do App Router) e propõe severidade e prazo; um humano confirma	R1 (D11)	PARADA 16

13.2 Severidade e prazos

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-VUL-03	Prazos de correção, contados da entrada no registro (detecção), pela severidade final: **crítica ou com exploração ativa (CISA KEV): 72 horas; alta: 7 dias; média: 30 dias; baixa: no próximo ciclo**, que é a próxima release publicada, em no máximo 90 dias (proposto). A severidade de partida é a do aviso (CVSS: crítica 9,0 a 10,0; alta 7,0 a 8,9; média 4,0 a 6,9; baixa 0,1 a 3,9). Vulnerabilidade no KEV fica com prazo de 72 h qualquer que seja o CVSS. Versão afetada fora de uso → `NAO_AFETA`, com evidência	plano da aula 3; `SECURITY.md`	O relatório semanal mostra, para cada registro aberto, o prazo e se está vencido	R1 (D11)	`seguranca-diaria.yml`; SEG-VUL-07

13.3 Registro

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-VUL-04	Registro em `docs/seguranca/VULNERABILIDADES.md` do repositório do sistema, uma entrada por vulnerabilidade e por componente, com o identificador `VULN-AAAA-nnn` (ano da detecção e sequência) e os campos da tabela abaixo. Nada é apagado: a entrada muda de situação	plano da aula 3; P-08 (por analogia)	Toda issue de vulnerabilidade cita o `VULN-*`; todo `VULN-*` aberto tem issue	R1 (D11)	conferência no `seguranca-diaria.yml`
SEG-VUL-05	Correção: versão mais nova do mesmo componente (patch, minor ou major) pelo PR do Renovate, sem quarentena (SEG-SUP-02), com a CI completa e merge humano; o PR de major atualiza o registro de versões (SEG-SUP-03). Troca de pacote ou dependência nova: issue que pede ADR (P-13). O registro só fecha (`CORRIGIDA`) com a CI verde e o achado ausente na varredura seguinte	ADR-0012 (revisão de 01/11/2026); P-13	Registro `CORRIGIDA` aponta o PR e a execução da varredura que já não acha	R1 (D11)	AUD-SEG; PARADA 16
SEG-VUL-06	Risco aceito: só com dono, motivo, mitigação e validade de no máximo 90 dias (proposto), aprovado pela TI; espelhado no `osv-scanner.toml` com `ignoreUntil` e motivo. Vencida a validade, a varredura volta a falhar	ASVS V15	Exceção sem validade ou sem motivo → o `seguranca-ci.yml` falha	R1 (D11)	job `excecoes` do `seguranca-ci.yml`

Campos de cada entrada `VULN-AAAA-nnn`:

Campo	Conteúdo
Identificadores	CVE, GHSA ou OSV
Componente	pacote ou imagem, versão em uso, onde (lockfile, imagem) e se é dependência direta ou transitiva
Fonte e data	fonte que detectou e data e hora da detecção (UTC)
Severidade da fonte	CVSS e vetor, como publicados
KEV	sim ou não, com a data de inclusão no catálogo
Alcance	em uso (sim ou não); chamada à parte vulnerável (sim, não ou indeterminado) com a evidência (arquivo e linha da importação ou rota)
Severidade final e prazo	severidade depois da triagem, quem confirmou e o vencimento (SEG-VUL-03)
Situação	`ABERTA`, `EM_CORRECAO`, `CORRIGIDA`, `NAO_AFETA` ou `RISCO_ACEITO`

Campo	Conteúdo
Correção	PR, versão corrigida, linha do registro de versões (se major), ADR (se troca de pacote ou dependência nova)
Verificação	execução da varredura que confirma a correção
Issue	link da issue com o rótulo de severidade

13.4 Relatório e canal

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-VUL-07	Relatório semanal numa issue fixa: o que entrou, o que foi corrigido, o que está vencido, riscos aceitos que vencem nas próximas 2 semanas, rotação de segredo vencida (SEG-SEC-03), o estado do SBOM (número de componentes, pacotes novos, mantenedores trocados, diferença para a semana anterior), os componentes atrás da última versão estável com os dias de atraso e cada exceção do registro de versões com a condição de saída (SEG-SUP-09)	plano da aula 3; ADR-0012 (revisão de 01/11/2026)	A primeira execução semanal publica o relatório; a TI revisa (PARADA 16)	R1 (D11)	`seguranca-diaria.yml`, gatilho semanal
SEG-VUL-08	`SECURITY.md` na raiz do repositório do sistema com: o canal privado para comunicar vulnerabilidade (comunicação privada de vulnerabilidade do GitHub), a política de prazos (SEG-VUL-03) e o que o agente de segurança faz e não faz	ASVS V15; plano da aula 3	Arquivo presente e com as três partes	R1 (D11)	AUD-SEG

14. Testes de segurança por etapa

ID	Teste	Ferramenta	Onde roda	Falha (bloqueia) quando
SEG-TST-01	SAST	Semgrep com os pacotes `p/typescript`, `p/react`, `p/owasp-top-ten` e as regras próprias de `.semgrep/` (`fetch-fora-de-adaptador` P-03, `process-env-fora-config` P-12, `html-perigoso`, `sql-inseguro`, `eval-dinamico`, `token-em-storage`, `dado-pessoal-em-url`, `cpf-literal`, `child-process`); CodeQL (`javascript-typescript`, consultas `security-extended`)	PR e semanal	achado de severidade `ERROR` no Semgrep; alerta de severidade alta ou crítica no CodeQL
SEG-TST-02	Dependências	`npm audit --omit=dev --audit-level=high`; `npm audit` completo (só relatório); OSV-Scanner (`osv-scanner scan source` no lockfile e `osv-scanner scan image` na imagem)	PR (lockfile), build e noite (lockfile e imagem)	vulnerabilidade alta ou crítica em dependência de produção; qualquer vulnerabilidade do OSV fora das exceções vigentes (SEG-VUL-06)
SEG-TST-03	Segredos	gitleaks: diferença do PR, histórico inteiro e sistema de arquivos da imagem	PR (diferença), noite (histórico), build (imagem)	qualquer achado não marcado como falso positivo com motivo no `.gitleaksignore`
SEG-TST-04	DAST	OWASP ZAP baseline (`zap-baseline.py`, imagem `ghcr.io/zaproxy/zaproxy:stable` fixada por digest) contra a homologação, com regras em `.zap/regras.tsv`	depois de cada deploy em homologação e semanal	alerta de risco alto; alerta médio vira registro para triagem

ID	Teste	Ferramenta	Onde roda	Falha (bloqueia) quando
SEG-TST-05	Autorização	testes de SEG-AUZ-01 a 06, gerados da matriz de 14 §1 e do OpenAPI; AT-25	PR (dentro de G-04, G-07 e G-09)	qualquer diferença entre matriz, `permite` e `x-perfis`; qualquer acesso cruzado que não responda 404
SEG-TST-06	Cabeçalhos, CSP e superfície	testes de SEG-CAB-01 a 05; no deploy, conferência dos cabeçalhos por requisição à homologação e da lista de domínios e proxies (SEG-INF-01)	PR (G-07, G-09) e deploy	cabeçalho ausente ou diferente; violação de CSP no e2e; porta pública além do `web`
SEG-TST-07	Entrada e envio	testes de SEG-ENT-01 a 09; AT-22	PR (G-04, G-07)	qualquer teste vermelho
SEG-TST-08	Revisão independente	auditoria D9 com as tabelas deste documento como lista ASVS nível 2; skill `auditar-seguranca` e `security-review` no código inteiro; relatório `AUD-SEG-nn`	a cada release	achado crítico ou alto aberto (PARADA 14)

15. Resposta a incidente: o mínimo

ID	Requisito	Origem	Critério de aceite	Release	Verificação
SEG-INC-01	Todo incidente de segurança tem registro `INC-AAAA-nnn` em `docs/seguranca/INCIDENTES.md` do repositório do sistema, com dono (TI), linha do tempo, dados afetados e ações	ASVS V16; 14 §4	Registro aberto no mesmo dia da detecção	R1 (D11)	AUD-SEG
SEG-INC-02	Conter: revogar sessões (troca de `NEXTAUTH_SECRET` derruba todas; versão da sessão derruba as de um usuário), trocar os segredos expostos (SEG-SEC-03), tirar o serviço do ar se preciso, preservar log e trilha antes de qualquer restauração	ASVS V16, V13; 14 §2 e §5	Passos no `RUNBOOK_DEPLOY.md`, com os comandos do Railway	R1 (D10)	exercício de mesa na PARADA 15
SEG-INC-03	Comunicar: com dado pessoal, ao encarregado da agência no mesmo dia, para avaliar a comunicação à ANPD (Lei 13.709/2018, art. 48; 14 §4); sempre à TI e à gestão	14 §4	Contatos no runbook	R1 (D10)	PARADA 15
SEG-INC-04	Recuperar e aprender: restaurar pelo 14 §7.1; relatório pós-incidente em até 5 dias úteis (proposto), com a causa e o teste ou a regra nova que pegaria o caso	ASVS V16	Relatório com o teste novo citado	R1 (D11)	AUD-SEG

16. Exceções registradas

ID	Exceção	Risco	Mitigação até lá	Dono	Até quando
EXC-SEG-01	Sem segundo fator na R1. O ASVS 5.0 nível 2 pede; o ADR-0009 só tem credenciais	senha vazada dá acesso	senha forte e lista de senhas comuns (SEG-AUT-01), bloqueio (SEG-AUT-03), limite por IP (SEG-LIM-01), sessão curta (SEG-SES-02), alerta de rajada (SEG-LOG-04), nenhum dado real antes da PARADA 15	TI	decisão da TI antes de dado real: login gov.br ou diretório da agência (trazem o segundo fator, ADR-0009) ou TOTP próprio (dependência nova, ADR pela P-13)

ID	Exceção	Risco	Mitigação até lá	Dono	Até quando
EXC-SEG-02	Sem antivírus nos arquivos recebidos	PDF malicioso guardado e baixado por servidor	o servidor não abre o PDF (SEG-ENT-07); download como anexo com `sandbox` e `nosniff` (SEG-ENT-05); tipo conferido pelo conteúdo (SEG-ENT-03)	TI	decisão da TI; antivírus seria serviço novo (P-13, ADR)
EXC-SEG-03	IPEADATA por `http://` (05 §15, endereço do oráculo)	troca de valor no caminho	conferência dos valores com a fonte e entre fontes (V07, V08); série pública, sem dado sigiloso	quem implementa HIS-SER-01	conferir no D2 se a fonte aceita HTTPS; se aceitar, trocar o endereço
EXC-SEG-04	Recursos do GitHub que dependem do plano em repositório privado: CodeQL e revisão de dependências (GitHub Code Security), atestados de proveniência, proteção de ramo e revisores obrigatórios de ambiente	lacuna de SAST ou de controle de merge	conferir no D0 o que o plano oferece; sem CodeQL, o SAST fica com o Semgrep e a lacuna vai para o AUD-SEG (o CodeQL não roda fora dos termos de licença); sem atestado, vale a cadeia de digest (SEG-INF-04); sem proteção de ramo, a regra de merge humano vale por processo e é conferida na auditoria	TI	D0
EXC-SEG-05	O Railway não bloqueia a saída para a internet do Gotenberg (05 §3 pede "sem acesso à internet")	conversão buscar recurso externo	busca remota e webhooks desligados (SEG-INF-05); o sistema só envia DOCX gerado pelo próprio modelo	TI	revisão na PARADA 15

17. Itens propostos que tocam outros documentos

Estes itens nascem aqui e precisam entrar no documento de origem na próxima revisão do pacote:

- variáveis de ambiente novas para 05_ARQUITETURA.md (documento 05, Arquitetura e decisões registradas) §15: `PACOTE_MAX_BYTES`, `ARQUIVO_MAX_BYTES`, `INTEGRACOES_HOSTS_PERMITIDOS`; o valor `openrouter` de `LLM_PROVEDOR` e a chave `OPENROUTER_API_KEY` (adendo do ADR-0006); os limites de SEG-LIM-01 e SEG-LIM-02 como parâmetros de configuração;
- segredos novos para 14_OPERACAO.md (documento 14, Operação, acesso e LGPD) §5: `OPENROUTER_API_KEY`, `RAILWAY_TOKEN` (por ambiente), senhas dos papéis do banco e dos usuários de teste (SEG-SEC-03);
- contagem dos eventos de segurança no JOB-03 (05 §12; SEG-LOG-04);
- a linha "Onde o sistema roda" da PARADA 11 (README.md) tem padrão provisório de aula: Railway (ADR-0013). A linha "Provedor do modelo de linguagem" tem padrão provisório: OpenRouter (adendo do ADR-0006). As duas continuam decisões da TI e da Procuradoria para dado real.

18. Matriz de verificações

Quando cada verificação roda. "PR": todo pull request (`verificar.yml`, com G-01 a G-11, e `seguranca-ci.yml`). "Noite": execução diária (`seguranca-diaria.yml`). "Deploy": `deploy.yml`, a cada etiqueta de versão, em homologação e na promoção para produção. "Semanal": gatilho semanal do `seguranca-diaria.yml` e do CodeQL. "Bloqueia" diz se a falha impede o merge, o deploy ou a promoção; o que não bloqueia abre issue ou registro.

Verificação	IDs	Ferramenta	PR	Noite	Deploy	Semanal	Bloqueia
Testes de autorização pela matriz de 14 §1 e do OpenAPI	SEG-AUZ-01 a 06, SEG-TST-05	Vitest, Playwright (AT-25)	sim	—	—	—	sim (merge)
Autenticação, sessão e CSRF	SEG-AUT-01 a 04, 06; SEG-SES-01 a 05	Vitest, Playwright	sim	—	—	—	sim (merge)
Entrada e envio do pacote	SEG-ENT-01 a 09, SEG-TST-07	Vitest	sim	—	—	—	sim (merge)
Cabeçalhos e CSP nos testes	SEG-CAB-01 a 05	Vitest, Playwright	sim	—	—	—	sim (merge)
Limite de requisições	SEG-LIM-01 a 03	Vitest	sim	—	—	—	sim (merge)
Redação de log e erro sem detalhe	SEG-LOG-02, SEG-LOG-03	Vitest	sim	—	—	—	sim (merge)
SAST Semgrep	SEG-TST-01	Semgrep	sim	—	—	—	sim (merge)
SAST CodeQL	SEG-TST-01	CodeQL (se o plano permitir, EXC-SEG-04)	sim	—	—	sim	sim (merge)
Dependências no lockfile	SEG-TST-02	`npm audit`, OSV-Scanner	sim	sim	—	—	sim no PR; issue à noite
Varredura da imagem	SEG-TST-02	OSV-Scanner	—	sim	sim	—	sim (deploy); issue à noite
Segredos	SEG-SEC-01, SEG-TST-03	gitleaks	sim (diferença)	sim (histórico)	sim (imagem)	—	sim (merge e deploy)
Lockfile e registro único	SEG-SUP-01	`npm ci`, verificação do `resolved`	sim	—	sim	—	sim
Dependência, imagem ou serviço novo sem ADR	SEG-SUP-03	job `dependencias-novas`	sim	—	—	—	sim (merge)
Assinaturas do registro npm	SEG-SUP-06	`npm audit signatures`	sim	sim	sim	—	sim
Exceções vencidas ou sem motivo	SEG-VUL-06	job `excecoes`	sim	sim	—	—	sim (merge); issue à noite

Verificação	IDs	Ferramenta	PR	Noite	Deploy	Semanal	Bloqueia
SBOM CycloneDX (lockfile e imagem)	SEG-SUP-05	`npm sbom`, Syft	—	sim	sim	—	sim (deploy sem SBOM não segue)
Cruzamento com OSV, GitHub Advisory, CISA KEV, avisos do Next.js, React e Prisma, imagens base, e triagem	SEG-VUL-01 a 05	`seguranca-diaria.yml`, OpenRouter	—	sim	—	—	não (abre registro, issue e PR do Renovate)
Pacote novo, mantenedor trocado, script de instalação novo	SEG-SUP-07	diferença de SBOM, `npm view`	—	sim	—	—	não (issue)
Componentes atrás da última versão estável e prazos vencidos	SEG-SUP-09	`npm outdated`, etiquetas das imagens, versões das actions, registro de versões	—	sim	—	sim (no relatório)	não (issue `versao-atrasada`)
Proveniência e digest da imagem	SEG-SUP-06, SEG-INF-04	`deploy.yml` (atestado se o plano permitir)	—	—	sim	—	sim (deploy)
Superfície pública, papéis do banco e usuário sem root	SEG-INF-01 a 03	API do Railway; AT-26 no smoke; `railway ssh` no runbook	—	—	sim	—	sim (promoção)
Cabeçalhos na homologação	SEG-CAB-02, 03, SEG-TST-06	requisição HTTP no `deploy.yml`	—	—	sim	—	sim (promoção)
DAST	SEG-TST-04	OWASP ZAP baseline	—	—	sim (homologação)	sim	sim (promoção) para alerta alto
Relatório semanal	SEG-VUL-07, SEG-SEC-03	`seguranca-diaria.yml`	—	—	—	sim	não
Auditoria independente	SEG-TST-08	`AUD-SEG-nn`	—	—	antes da produção	—	sim (PARADA 14)